

IDRIS KHIDIROV

LOCKDOWN LAB ANALYSIS

Şəbəkə Trafikinin, Yaddaş Dampının və Zərərli Proqram Nümunəsinin Analizi

Hesabatın hazırlanma tarixi: 17.09.2026

1. Giriş və Ssenari

TechNova Systems şirkətinin SOC komandası bulud infrastrukturunda yerləşən, internetə açıq bir IIS serverindən gedən (outbound) şübhəli trafik aşkar edib. Bu fəaliyyət veb-shell yerləşdirilməsinə və naməlum bir host ilə gizli əlaqəyə işarə edirdi. Ekspertiza zamanı üç əsas artefaktdan istifadə olunub: ilkin hücum trafikini əks etdirən PCAP faylı, serverin tam yaddaş surəti (memory image) və diskdən əldə edilmiş zərərli proqram nümunəsi. Bu hesabatın məqsədi — həmin üç artefaktı ardıcıl təhlil edərək sızmanın necə baş verdiyini və hücumçunun bütün addımlarını bərpa etməkdir ki, TechNova insidenti tam əhatə edə və müdafiəsini gücləndirə bilsin.

2. Metodologiya

Araşdırma üç ardıcıl mərhələdə aparılıb, hər mərhələdə fərqli alətlərdən istifadə olunub:

- Wireshark — PCAP faylı üzərində şəbəkə trafikinin təhlili üçün;
- Volatility 3 — server yaddaş dampının (memory dump) analizi üçün;

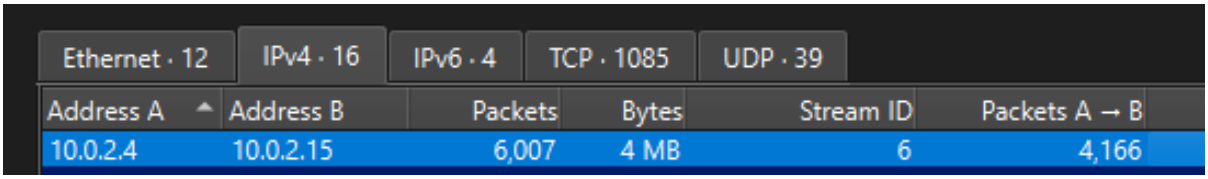
- Linux strings əmri — zərərli proqram nümunəsinin statik təhlili üçün;
- VirusTotal — hash və domen üzərindən threat-intel araşdırması üçün.

3. Hissə I — Şəbəkə Trafikinin Analizi (PCAP)

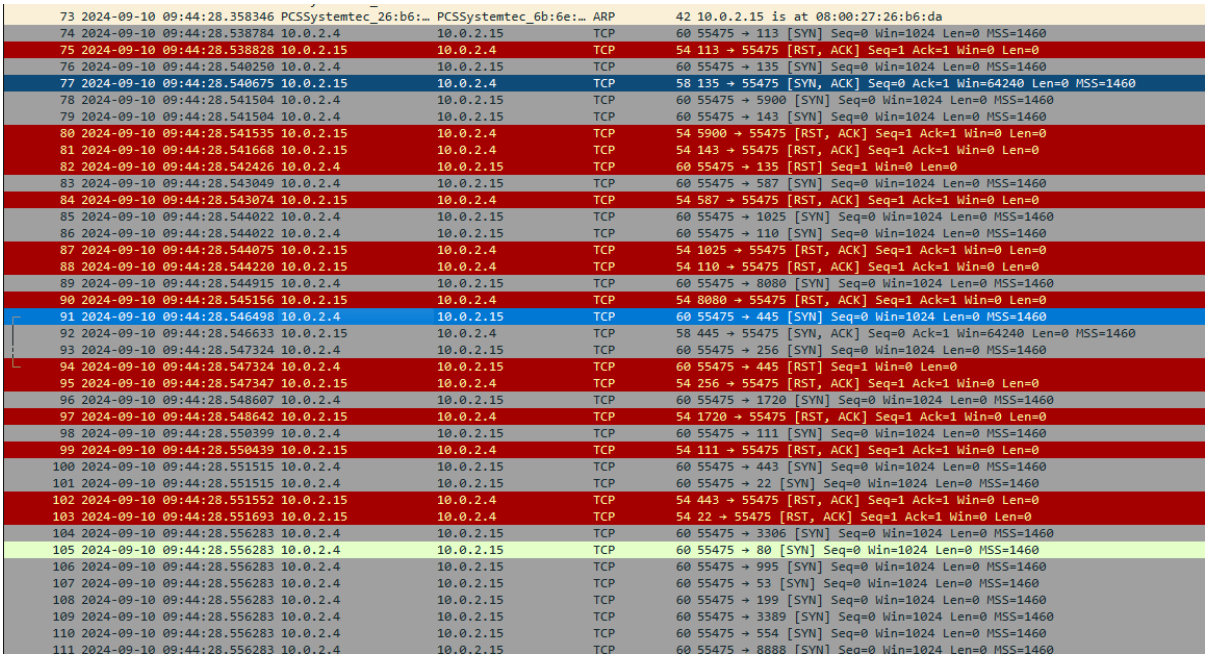
Bu mərhələdə paylaşılan PCAP faylı Wireshark proqramında açılıb və hücumun ilkin izləri addım-addım izlənilib.

3.1 Kəşfiyyat (Reconnaissance) Fəaliyyətinin Mənbəyi

İlk növbədə Statistics → Conversations bölməsinə baxılıb. Burada bir IP ünvanının digərinə qeyri-adi şəkildə çox — 4166 paket göndərdiyi müşahidə olunub (ümumi 6007 paketdən ibarət söhbətin böyük hissəsi). Həmin söhbət filtr kimi tətbiq edilib və paket siyahısı nəzərdən keçirildikdə 10.0.2.4 ünvanının 10.0.2.15 ünvanının çoxsaylı müxtəlif portlarına ardıcıl SYN paketləri göndərdiyi aşkarlanıb. Bu, klassik port skanının (reconnaissance) açıq göstəricisidir.



Şəkil 1 — 10.0.2.4 və 10.0.2.15 arasındakı söhbətin statistikası (Statistics → Conversations).

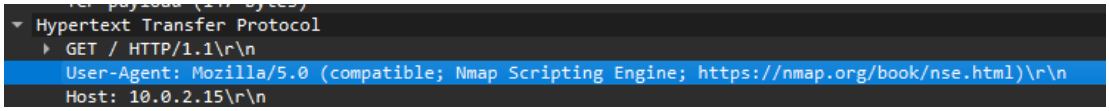


Şəkil 2 — 10.0.2.4 ünvanından 10.0.2.15-in müxtəlif portlarına göndərilən ardıcıl SYN paketləri.

> **Tapıntı: Kəşfiyyat trafikini yaradan IP ünvanı** — 10.0.2.4

3.2 İstifadə Olunan Alətin Müəyyənləşdirilməsi

Hücumçunun hansı alətdən istifadə etdiyini müəyyən etmək üçün HTTP trafikinə baxılıb. 10.0.2.4-dən gələn bir GET sorğusunun User-Agent sahəsi araşdırılanda bunun Nmap Scripting Engine-ə aid olduğu görünüb — yəni port skanından sonra hədəf üzərində Nmap vasitəsilə əlavə xidmət/versiya araşdırması aparılıb.



Şəkil 3 — HTTP sorğusunun User-Agent başlığı: Nmap Scripting Engine.

> **Tapıntı: Aşkarlanan alət** — Nmap

3.3 SMB Paylaşımlarına Giriş

Növbəti addımda SMB trafiki (ip.addr==10.0.2.4 && smb2 filtri ilə) araşdırılıb. Trafikdə 10.0.2.4 ünvanının IIS host üzərində iki fərqli share-ə Tree Connect sorğusu göndərdiyi müəyyən edilib: \\10.0.2.15\Documents və \\10.0.2.15\IPC$. Bu, hücumçunun serverdə hansı fayl paylaşımlarının mövcud olduğunu araşdırdığını göstərir.



Şəkil 4 — \\10.0.2.15\IPC$ share-nə göndərilən Tree Connect Request/Response.

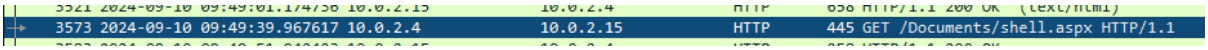


Şəkil 5 — \\10.0.2.15\Documents share-nə göndərilən Tree Connect Request/Response.

> **Tapıntı: Giriş edilən share-lər** — \\10.0.2.15\Documents, \\10.0.2.15\IPC$

3.4 Zərərli Veb-Shell-in Yerləşdirilməsi

HTTP trafiki (ip.addr==10.0.2.4 && http filtri ilə) yenidən nəzərdən keçirildikdə, hücumçunun Remote Code Execution (RCE) əldə etmək üçün Documents share-i üzərindən shell.aspx adlı fayla GET sorğusu göndərdiyi aşkarlanıb. Bu, əvvəlki addımda tapılan Documents share-nin əslində veb üzərindən əlçatan olduğunu və hücumçunun ora zərərli faylı əvvəlcədən yerləşdirdiyini göstərir.

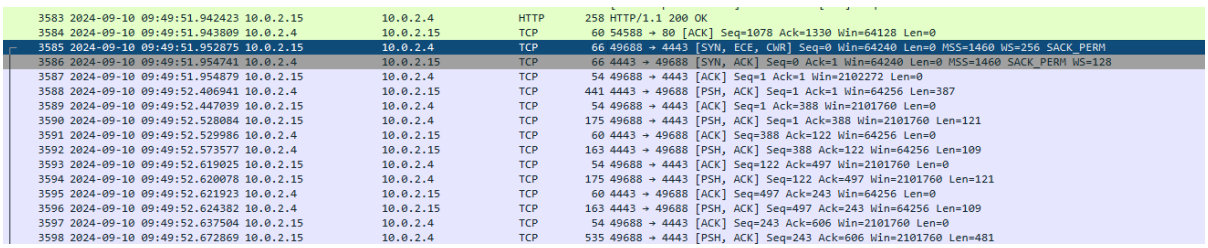


Şəkil 6 — /Documents/shell.aspx faylına göndərilən HTTP GET sorğusu.

> **Tapıntı: Yerləşdirilən zərərli fayl** — shell.aspx

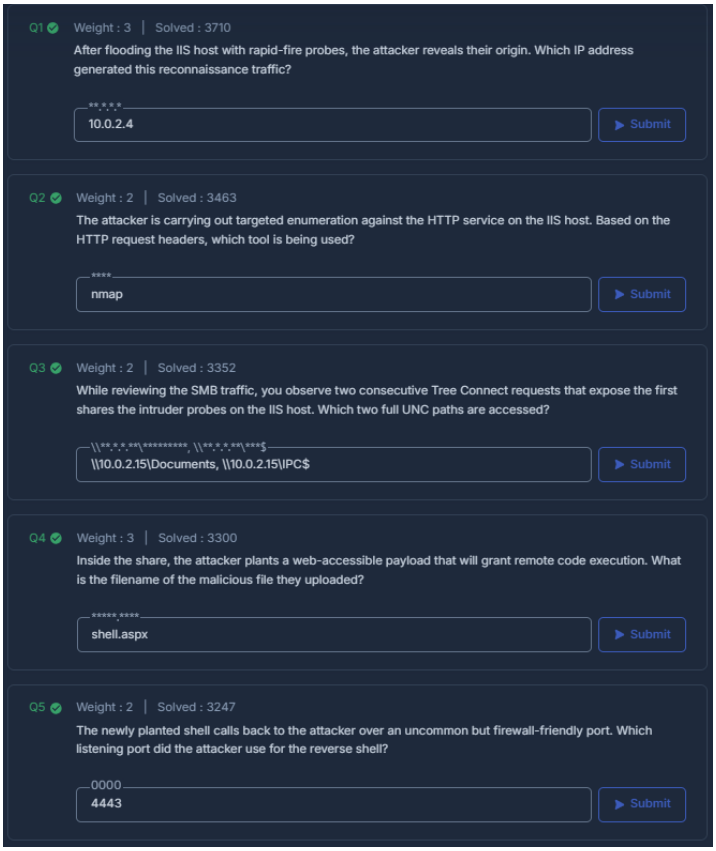
3.5 Reverse Shell Bağlantısı

Son olaraq TCP trafiki izlənərək reverse shell üçün istifadə olunan portun tapılması tələb olunub. Trafikdə 10.0.2.15 (server) tərəfindən 10.0.2.4-ə (hücumçu) doğru 4443 portuna açıq şəkildə TCP bağlantısı quruldugu görünüb — bu, veb-shell vasitəsilə əldə edilmiş RCE-nin artıq real bir reverse shell-ə çevrildiyini göstərir. Maraqlıdır ki, bu bağlantının Wireshark-dakı yerli vaxtı (09:49:51, UTC+4) sonrakı yaddaş dampı analizində tapılacaq bağlantı vaxtı (05:49:51 UTC) ilə tam üst-üstə düşür — bu da hər iki artefaktın eyni hadisəni təsdiqlədiyini göstərir.



Şəkil 7 — 10.0.2.15-dən 10.0.2.4:4443 ünvanına qurulan TCP bağlantısı (reverse shell).

> **Tapıntı: Reverse shell portu** — 4443/TCP



Şəkil 8 — PCAP təhlili üzrə platformada təsdiqlənmiş cavablar (Q1–Q5).

4. Hissə II — Yaddaş Dampının Analizi (Volatility 3)

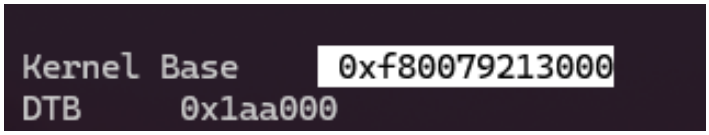
Bu mərhələdə serverin tam yaddaş surəti Volatility 3 çərçivəsi ilə araşdırılıb, məqsəd hücumçunun sistemdə qoyduğu izləri və davamlılıq (persistence) mexanizmini tapmaq olub.

4.1 Kernel Base Address

İlk addımda windows.info plugin-i işə salınaraq yaddaş dampının əsas sistem məlumatları əldə edilib. Bu, dampın bütövlüyünü təsdiqləyən və sonrakı təhlil üçün baza yaradan ilkin addımdır.

```
PS C:\Users\idris\Desktop\269-lockdown> vol -f .\memdump.mem windows.info
```

Şəkil 9 — windows.info plugin-inin işə salınması.



Şəkil 10 — windows.info nəticəsində tapılan Kernel Base Address.

> **Tapıntı: Kernel Base Address** — 0xf80079213000

4.2 Davamlılıq (Persistence) Mexanizminin Aşkarlanması

windows.netscan plugin-i vasitəsilə proseslərin yaratdığı şəbəkə bağlantılarına baxılıb. Nəticədə w3wp.exe (IIS worker process, PID 4332) prosesinin 10.0.2.4:4443 ünvanı ilə bağlantı yaratdığı görünüb — yəni əvvəlki mərhələdə tapılan reverse shell birbaşa bu proses üzərindən idarə olunub.

```
PS C:\Users\idris\Desktop\269-lockdown> vol -f .\memdump.mem windows.netscan
```

Şəkil 11 — windows.netscan plugin-inin işə salınması.



Şəkil 12 — w3wp.exe (PID 4332) prosesinin 10.0.2.4:4443 ünvanı ilə bağlantısı.

Bu proses windows.psscan plugin-i ilə daha ətraflı yoxlanılıb və onun ana (parent) prosesinin PID 2452 olduğu müəyyən edilib

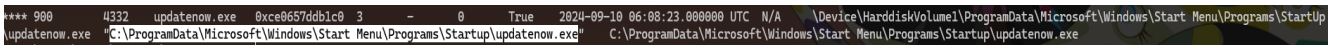


Şəkil 13 — windows.psscan nəticəsi: PID 4332, Parent PID 2452, w3wp.exe.

Sonda həmin ana prosesin (PID 2452) uşaq prosesləri windows.pstree --pid 2452 əmri ilə araşdırılıb. Bu, etibarlı xidmətin server üçün qeyri-adi olan, IIS stack-dən kənar bir icra faylı işə saldığını üzə çıxarıb: Startup qovluğuna yerləşdirilmiş updatenow.exe. Bu fayl növbəti sistem açılışında avtomatik işə düşəcək şəkildə qurulub, yəni klassik bir persistence implantıdır.

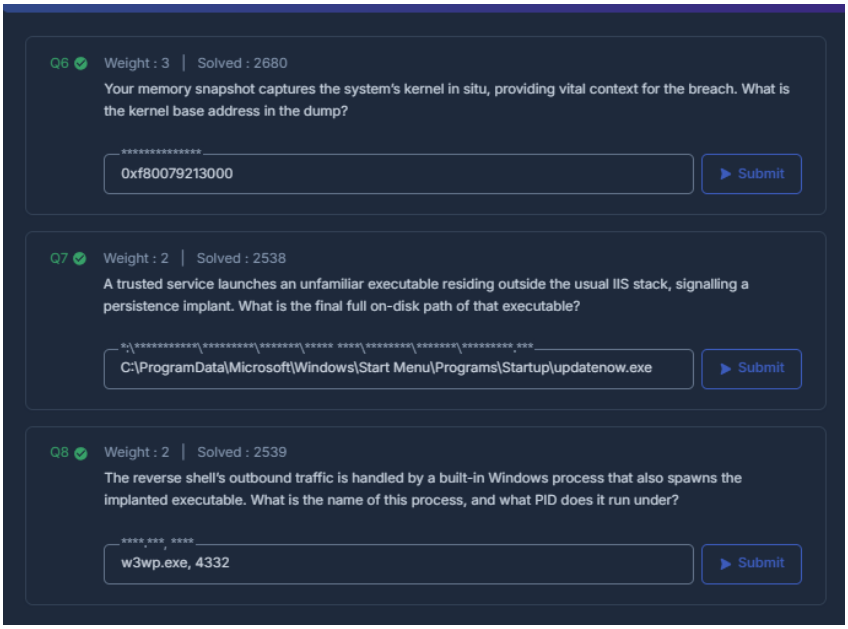


Şəkil 14 — windows.pstree --pid 2452 əmrinin işə salınması.



Şəkil 15 — updatenow.exe faylının tam diskdəki yolu və yaradılma vaxtı (2024-09-10 06:08:23 UTC).

> **Tapıntı: Reverse shell-i idarə edən proses** — w3wp.exe (PID 4332), ana proses PID 2452
>
> **Tapıntı: Persistence faylının tam yolu** — C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\updatenow.exe



Şəkil 16 — Yaddaş dampı təhlili üzrə platformada təsdiqlənmiş cavablar (Q6–Q8).

5. Hissə III — Zərərli Proqram Nümunəsinin Analizi

Son mərhələdə diskdən əldə edilmiş nümunə (updatenow.exe) Ubuntu mühitinə keçirilərək statik təhlildən keçirilib.

5.1 Packer İdentifikasiyası

Faylın strings əmri ilə statik təhlili aparılıb. Nəticədə fayl daxilində UPX0 və UPX1 seksiyalarının adları aşkarlanıb — bu, faylın UPX packer ilə sıxıldığını və analiz çətinləşdirmək məqsədi daşıdığını göstərir.

```
idris@idris-VMware-Virtual-Platform:~/Downloads/269-lockdown$ strings updatenow.exe
!This program cannot be run in DOS mode.
RichR
UPX0
UPX1
```

Şəkil 17 — strings updatenow.exe nəticəsində görünən UPX0/UPX1 seksiyaları.

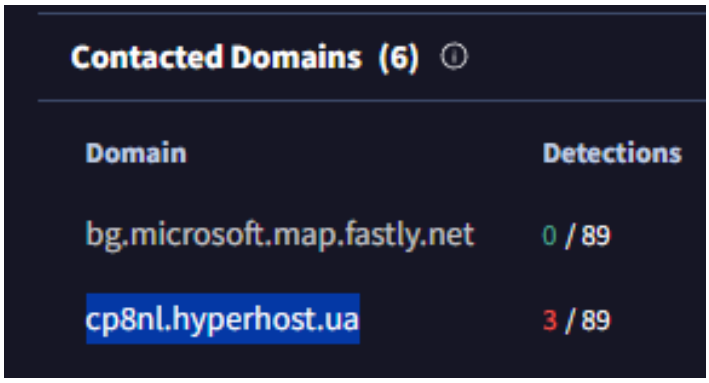
> **Tapıntı: Aşkarlanan packer** — UPX

5.2 Command-and-Control (C2) Domeninin Müəyyənləşdirilməsi

Faylın SHA-256 hash-i çıxarılaraq VirusTotal üzərində axtarılıb. Nəticələrin "Relations → Contacted Domains" bölməsində fayl ilə əlaqəli 6 domen aşkarlanıb, onlardan biri — cp8nl.hyperhost.ua — 89 vendordan 3-ü tərəfindən şübhəli (suspicious) kimi qeyd edilib. Bu, zərərli proqramın əlaqə saxladığı C2 domeni olaraq qəbul edilib.

```
idris@idris-VMware-Virtual-Platform:~/Downloads/269-lockdown$ sha256sum  updatenow.exe
c25a6673a24d169de1bb399d226c12cdc666e0fa534149fc9fa7896ee61d406f  updatenow.exe
```

Şəkil 18 — updatenow.exe faylının SHA-256 hash-i.



Şəkil 19 — VirusTotal-da aşkarlanan Contacted Domains siyahısı.

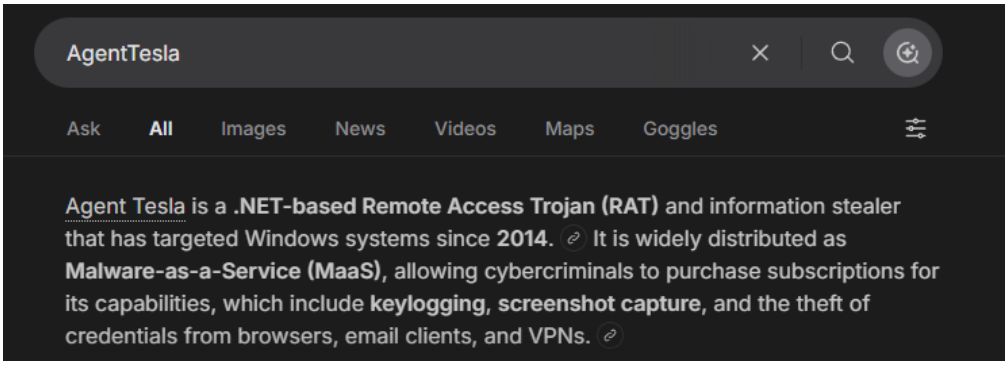
> **Tapıntı: C2 domeni (FQDN)** — cp8nl.hyperhost.ua

5.3 Zərərli Proqram Ailəsinin Təyini

VirusTotal-ın vendor analizi bölməsində AliCloud mühərriki nümunəni Trojan:Win/AgentTesla.SHZT kimi işarələyib. Açıq mənbələr üzərindən aparılan əlavə araşdırma bu adlandırmanı təsdiqləyib: AgentTesla 2014-cü ildən bəri Windows sistemlərini hədəf alan, .NET əsaslı Remote Access Trojan (RAT) və məlumat oğurlayan (infostealer) zərərli proqramdır. O, Malware-as-a-Service modeli ilə paylanır və keylogging, ekran şəkli çəkmə, brauzer/e-poçt/VPN tətbiqlərindən məlumat oğurlama kimi imkanlara malikdir.

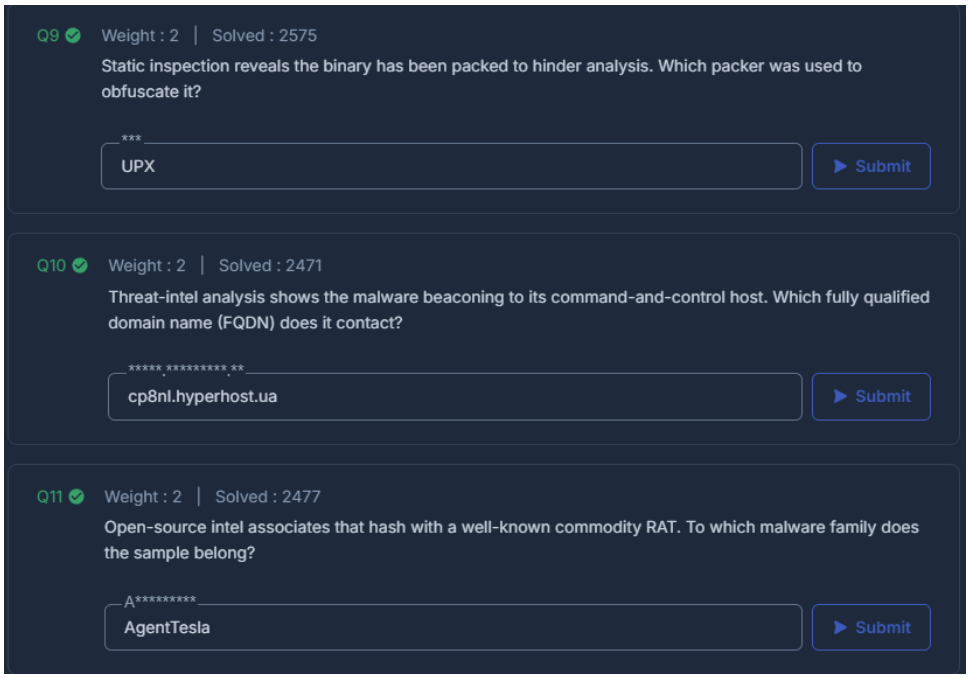


Şəkil 20 — AliCloud mühərriki tərəfindən verilən Trojan:Win/AgentTesla.SHZT təsnifatı.



Şəkil 21 — AgentTesla RAT-ı haqqında açıq mənbə (OSINT) təsdiqi.

> **Tapıntı: Zərərli proqram ailəsi** — AgentTesla (RAT / infostealer)



Şəkil 22 — Zərərli proqram təhlili üzrə platformada təsdiqlənmiş cavablar (Q9–Q11).

6. Nəticə və Ümumi Xülasə

Aparılan üç mərhələli təhlil bir-birini tam təsdiqləyən, ardıcıl bir hücum zəncirini üzə çıxarıb: 10.0.2.4 ünvanından Nmap ilə edilən kəşfiyyatdan başlayaraq, açıq SMB share-i vasitəsilə shell.aspx veb-shell-inin yerləşdirilməsi, 4443 portu üzərindən reverse shell əldə edilməsi, w3wp.exe prosesi vasitəsilə updatenow.exe adlı AgentTesla RAT-ının Startup qovluğuna yazılaraq davamlılıq (persistence) təmin edilməsi və son olaraq cp8nl.hyperhost.ua C2 domeni ilə əlaqə. Bütün tapıntıların xülasəsi aşağıdakı cədvəldə göstərilib.

Araşdırma istiqaməti	Nəticə
Kəşfiyyat (reconnaissance) IP-si	10.0.2.4
İstifadə olunan skan aləti	Nmap
Giriş edilən SMB share-lər	\\10.0.2.15\Documents, \\10.0.2.15\IPC$

Araşdırma istiqaməti	Nəticə
Yerləşdirilən zərərli fayl (web shell)	shell.aspx
Reverse shell üçün istifadə olunan port	4443/TCP
Kernel Base Address	0xf80079213000
Persistence faylının tam yolu	C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\updatenow.exe
Reverse shell-i idarə edən proses / PID	w3wp.exe / PID 4332
Nümunədə aşkarlanan packer	UPX
C2 domeni (FQDN)	cp8nl.hyperhost.ua
Zərərli proqram ailəsi	AgentTesla (RAT / infostealer)